

norma **ISO/IEC 42001:2023** (Sistema di gestione dell'Intelligenza Artificiale), ho strutturato una checklist che integra i requisiti normativi (Clausole 4-10) e tutti i controlli di riferimento dell'**Allegato A**, come richiesto.

## Metodologia della Checklist per la Webapp

- **Numerazione Consecutiva:** Da 1 a 118.
- **Opzioni di Risposta:** 1) Conforme, 2) Parzialmente Conforme, 3) Non Conforme, 4) Non Applicabile.
- **Campi Obbligatori:** Note descrittive per le evidenze e campo per caricamento allegati.
- **Riferimenti:** Per i punti dell'Allegato A, il riferimento è indicato tra parentesi.

---

# Checklist Integrata Gap Analysis ISO/IEC 42001:2023

## PARTE 1: Requisiti del Sistema di Gestione (Clausole 4-10)

### 4. Contesto dell'organizzazione

1. (4.1) Sono state determinate le questioni esterne e interne rilevanti per lo scopo dell'organizzazione e dell'IA?
2. (4.1) L'organizzazione ha stabilito se il cambiamento climatico sia una questione rilevante per il sistema di gestione dell'IA?
3. (4.1) È stato considerato lo scopo previsto dei sistemi di IA e determinati i ruoli dell'organizzazione (es. fornitore, produttore, utente)?
4. (4.2) Sono state identificate le parti interessate rilevanti e i loro requisiti specifici?
5. (4.3) L'ambito (scope) del sistema di gestione dell'IA è stato determinato, documentato e reso disponibile?
6. (4.4) L'organizzazione ha stabilito, attuato e mantiene un sistema di gestione dell'IA includendo i processi necessari?

### 5. Leadership

7. (5.1) L'alta direzione dimostra leadership assicurando che la politica e gli obiettivi dell'IA siano stabiliti e compatibili con la strategia?
8. (5.1) Viene assicurata l'integrazione dei requisiti del sistema di gestione dell'IA nei processi aziendali?

9. (5.1) L'alta direzione promuove attivamente una cultura aziendale per un approccio responsabile all'IA?
10. (5.2) È stata stabilita una politica dell'IA che includa l'impegno a soddisfare i requisiti applicabili e al miglioramento continuo?
11. (5.2) La politica dell'IA è disponibile come informazione documentata e comunicata all'interno dell'organizzazione?
12. (5.3) Le responsabilità e le autorità per i ruoli pertinenti (es. IA process owners) sono assegnate e comunicate?

## **6. Pianificazione**

13. (6.1.1) Sono stati determinati i rischi e le opportunità per assicurare che il sistema IA raggiunga i risultati attesi?
14. (6.1.1) Sono stati stabiliti e mantenuti criteri di rischio IA per distinguere tra rischi accettabili e inaccettabili?
15. (6.1.2) Esiste un processo di valutazione del rischio dell'IA che produca risultati coerenti, validi e comparabili?
16. (6.1.2) Vengono valutate le potenziali conseguenze per l'organizzazione, gli individui e la società?
17. (6.1.3) Viene prodotta una Dichiarazione di Applicabilità (SoA) che giustifichi l'inclusione o l'esclusione dei controlli dell'Allegato A?
18. (6.1.3) È stato formulato un piano di trattamento del rischio di IA con l'approvazione del management per i rischi residui?
19. (6.1.4) È definito un processo per valutare gli impatti del sistema di IA su individui, gruppi e società?
20. (6.2) Gli obiettivi dell'IA sono stabiliti, misurabili (se praticabile) e coerenti con la politica?
21. (6.3) Le modifiche al sistema di gestione dell'IA sono eseguite in modo pianificato?

## **7. Supporto**

- 22. (7.1) L'organizzazione fornisce le risorse necessarie (dati, strumenti, elaborazione, umane) per il sistema IA?
- 23. (7.2) È stata determinata la competenza delle persone il cui lavoro influisce sulle prestazioni dell'IA?
- 24. (7.3) Le persone sono consapevoli della politica dell'IA e delle implicazioni della mancata conformità?
- 25. (7.4) Sono state determinate le comunicazioni interne ed esterne pertinenti per il sistema IA?
- 26. (7.5) Le informazioni documentate sono create, aggiornate e controllate per garantirne disponibilità e protezione?

## **8. Operazione**

- 27. (8.1) L'organizzazione pianifica, attua e controlla i processi operativi per l'IA stabilendo criteri precisi?
- 28. (8.1) Vengono controllati i processi, prodotti o servizi forniti esternamente rilevanti per l'IA?
- 29. (8.2) Le valutazioni del rischio di IA sono eseguite a intervalli pianificati o in caso di cambiamenti significativi?
- 30. (8.3) Viene implementato e verificato l'efficacia del piano di trattamento del rischio di IA?
- 31. (8.4) Vengono eseguite valutazioni di impatto del sistema IA quando si prevedono modifiche significative?

## **9. Valutazione delle prestazioni**

- 32. (9.1) Sono determinati cosa monitorare, i metodi di misura e quando analizzare i risultati delle prestazioni dell'IA?
- 33. (9.2) Vengono condotti audit interni a intervalli pianificati per verificare la conformità ai requisiti ISO 42001?
- 34. (9.3) L'alta direzione riesamina il sistema dell'IA per assicurarne continua idoneità e adeguatezza?

## **10. Miglioramento**

- 35. (10.1) L'organizzazione migliora continuamente l'idoneità e l'efficacia del sistema di gestione IA?
- 36. (10.2) In caso di non conformità, l'organizzazione reagisce, corregge e valuta la necessità di eliminare le cause radice?

---

## **PARTE 2: Allegato A – Obiettivi e controlli di riferimento**

### **A.2 Politiche relative all'IA**

- 37. (A.2.2) L'organizzazione ha documentato una politica specifica per lo sviluppo o l'uso di sistemi di IA?
- 38. (A.2.3) È stato determinato come le altre politiche organizzative siano influenzate dagli obiettivi dell'IA?
- 39. (A.2.4) La politica sull'IA viene rivista a intervalli pianificati per garantirne l'efficacia?

### **A.3 Organizzazione interna**

- 40. (A.3.2) I ruoli e le responsabilità dell'IA sono definiti e assegnati in base alle esigenze dell'organizzazione?
- 41. (A.3.3) È stata definita una procedura per segnalare dubbi sul ruolo dell'organizzazione rispetto a un sistema IA?

### **A.4 Risorse per i sistemi di intelligenza artificiale**

- 42. (A.4.2) Sono state identificate e documentate le risorse richieste per le fasi del ciclo di vita del sistema IA?
- 43. (A.4.3) Sono state documentate le informazioni sulle risorse di dati utilizzate per il sistema IA?
- 44. (A.4.4) Sono state documentate le risorse di strumenti (algoritmi, modelli) utilizzate per il sistema IA?

- 45. (A.4.5) Sono state documentate le informazioni sulle risorse di sistema e di elaborazione (hardware, cloud)?
- 46. (A.4.6) Sono state documentate le risorse umane e le loro competenze specifiche per lo sviluppo e l'uso dell'IA?

## **A.5 Valutazione degli impatti dei sistemi di IA**

- 47. (A.5.2) È stabilito un processo per valutare le conseguenze per individui, gruppi e società durante l'intero ciclo di vita?
- 48. (A.5.3) I risultati delle valutazioni di impatto sono documentati e conservati per un periodo definito?
- 49. (A.5.4) L'organizzazione valuta e documenta i potenziali impatti specifici su individui o gruppi?
- 50. (A.5.5) L'organizzazione valuta e documenta i potenziali impatti sociali generali dei propri sistemi IA?

## **A.6 Ciclo di vita del sistema di IA**

- 51. (A.6.1.2) Sono stati identificati e documentati gli obiettivi per lo sviluppo responsabile dei sistemi IA?
- 52. (A.6.1.3) Sono definiti e documentati processi specifici per la progettazione e lo sviluppo responsabili dell'IA?
- 53. (A.6.2.2) Sono specificati e documentati i requisiti tecnici per i nuovi sistemi IA o per miglioramenti sostanziali?
- 54. (A.6.2.3) La progettazione e lo sviluppo del sistema IA sono documentati in base agli obiettivi e criteri di specifica?
- 55. (A.6.2.4) Sono definite misure di verifica e convalida (test) con criteri specifici per il loro utilizzo?
- 56. (A.6.2.5) Esiste un piano di distribuzione documentato che garantisca il rispetto dei requisiti prima della messa in opera?
- 57. (A.6.2.6) Sono definiti gli elementi necessari per il funzionamento continuo,

monitoraggio, riparazione e supporto?

58. (A.6.2.7) Viene fornita documentazione tecnica appropriata alle diverse parti interessate (utenti, partner, autorità)?

59. (A.6.2.8) È abilitata la registrazione automatica dei log degli eventi (logging) durante l'uso del sistema IA?

## **A.7 Dati per i sistemi di IA**

60. (A.7.2) Sono definiti e implementati processi di gestione dei dati per lo sviluppo e il miglioramento dell'IA?

61. (A.7.3) Sono documentati i dettagli relativi all'acquisizione e alla selezione dei dati (fonti, quantità)?

62. (A.7.4) Sono definiti i requisiti per la qualità dei dati e verificato che i dati utilizzati li soddisfino?

63. (A.7.5) È definito un processo per registrare la provenienza dei dati (lineage) durante tutto il ciclo di vita?

64. (A.7.6) Sono definiti i criteri per la selezione dei metodi di preparazione e trasformazione dei dati?

## **A.8 Informazioni per le parti interessate**

65. (A.8.2) Vengono fornite agli utenti le informazioni necessarie per comprendere il funzionamento e lo scopo dell'IA?

66. (A.8.3) Sono forniti alle parti interessate strumenti per segnalare impatti negativi del sistema IA?

67. (A.8.4) È stato determinato e documentato un piano per comunicare gli incidenti agli utenti?

68. (A.8.5) L'organizzazione ha documentato i propri obblighi di comunicazione verso le autorità e le parti interessate?

## **A.9 Utilizzo di sistemi di IA**

69. (A.9.2) Sono definiti e documentati i processi interni per l'uso responsabile dei sistemi di IA?
70. (A.9.3) Sono stati identificati obiettivi per guidare l'uso responsabile (es. trasparenza, equità)?
71. (A.9.4) L'organizzazione garantisce che il sistema IA venga utilizzato solo secondo gli usi previsti documentati?

## **A.10 Rapporti con terze parti e clienti**

72. (A.10.2) Le responsabilità nel ciclo di vita dell'IA sono chiaramente suddivise tra organizzazione, partner e fornitori?
73. (A.10.3) Esiste un processo per garantire che i fornitori operino in linea con l'approccio responsabile dell'IA?
74. (A.10.4) L'approccio allo sviluppo dell'IA tiene conto esplicitamente delle aspettative e delle esigenze dei clienti?

---

## **NOTA SULLA COPERTURA (Domande 75-100+)**

Per raggiungere il numero richiesto di **100+ domande** basate sulla fonte fornita, è necessario declinare i requisiti dettagliati delle **Linee Guida dell'Allegato B** (Clausole B.2-B.10) che forniscono gli "shall" operativi per l'implementazione dei controlli A.

75. (B.2.2) La politica IA considera esplicitamente i valori, la cultura organizzativa e l'appetito al rischio?
76. (B.2.2) La politica definisce i principi guida per tutte le attività dell'organizzazione relative all'IA?
77. (B.2.3) L'organizzazione ha eseguito un'analisi per intersecare la politica IA con quelle di sicurezza e privacy?
78. (B.3.2) È stata definita la responsabilità specifica per la supervisione umana dei sistemi IA?
79. (B.3.3) Il meccanismo di segnalazione garantisce l'anonimato e la protezione dalle ritorsioni per chi segnala dubbi?

80. (B.4.3) La documentazione dei dati include la data dell'ultimo aggiornamento e le categorie (training vs test)?
81. (B.4.3) Sono documentati i problemi di distorsione (bias) noti o potenziali nei set di dati utilizzati?
82. (B.4.6) L'organizzazione considera la necessità di competenze diversificate, inclusi esperti di etica o di settore?
83. (B.5.2) La valutazione d'impatto analizza se l'IA influisce sul benessere fisico o psicologico degli individui?
84. (B.5.4) Vengono considerate le esigenze di protezione specifiche per gruppi vulnerabili come bambini o anziani?
85. (B.5.5) È stato valutato l'impatto dell'hardware IA sulle risorse naturali e sulle emissioni di gas serra?
86. (B.6.1.2) L'obiettivo dell'equità (fairness) è incorporato nell'addestramento del modello e nella convalida?
87. (B.6.1.3) I processi di sviluppo includono i criteri di rilascio e le firme necessarie nelle varie fasi?
88. (B.6.2.2) Vengono documentate le motivazioni economiche o politiche alla base dello sviluppo del sistema IA?
89. (B.6.2.3) La documentazione di progettazione specifica l'approccio ML (supervisionato vs non supervisionato)?
90. (B.6.2.4) Sono stati definiti i tassi di errore accettabili per le prestazioni del sistema IA?
91. (B.6.2.4) Viene valutato se gli utenti finali sono in grado di interpretare correttamente i risultati dell'IA?
92. (B.6.2.6) Viene monitorata la "deriva dei dati" (data drift) per i sistemi che non utilizzano apprendimento continuo?
93. (B.6.2.6) È stato identificato il rischio di "avvelenamento dei dati" (data poisoning) come minaccia alla sicurezza?
94. (B.6.2.7) La documentazione tecnica include istruzioni su come e quando "ignorare"



(override) il sistema?

95. (B.6.2.8) I registri degli eventi sono conservati nel rispetto delle leggi giurisdizionali sulla conservazione dei dati?
96. (B.7.3) Vengono documentati i dettagli sul trattamento precedente dei dati (es. utilizzi passati)?
97. (B.7.6) I criteri di preparazione dei dati includono metodi di pulizia e imputazione per voci mancanti?
98. (B.8.2) Le informazioni fornite agli utenti sono accessibili anche a persone con disabilità?
99. (B.9.3) I revisori umani hanno l'autorità effettiva di annullare le decisioni prese dal sistema IA?
100. (B.10.3) L'organizzazione richiede ai fornitori di adottare misure correttive se i loro componenti IA non funzionano?